🔒 ឯកសារមេរៀនបច្ចេកទេស • TECHNICAL SECURITY GUIDE

ការការពារសុវត្ថិភាពប្រព័ន្ធគ្រប់គ្រងសាលារៀន

Web Application Security Architecture & Best Practices 2027

គម្រោង៖ ប្រព័ន្ធគ្រប់គ្រងថ្នាក់រៀន ២០២៧

គេហទំព័រ៖ https://class.mitpukae.com

បច្ចេកវិទ្យា៖ Spring Boot 3, Java 17, H2, Cloud

កាលបរិច្ឆេទ៖ ខែតុលា ឆ្នាំ២០២៦ (កំណែផ្លូវការ)

📑 **មាតិកានៃមេរៀន**

១. ទ្រឹស្តីគ្រឹះនៃសុវត្ថិភាពព័ត៌មាន (The CIA Triad)
២. ហានិភ័យទូទៅនៃការវាយប្រហារ (Common Threats)
៣. ស្ថាបត្យកម្មការពារ ៦ ស្រទាប់ (6-Layer Architecture)
៤. វិភាគករណីសិក្សាជាក់ស្តែង (Attack Scenarios)
៥. បញ្ជីត្រួតពិនិត្យអ្នកគ្រប់គ្រង (Admin Checklist)
៦. វចនានុក្រមបច្ចេកទេស (Security Glossary)

១. ទ្រឹស្តីគ្រឹះនៃសុវត្ថិភាពព័ត៌មាន (The CIA Triad)

នៅក្នុងវិស័យសន្តិសុខតាមប្រព័ន្ធអ៊ីនធឺណិត (Cybersecurity) ការការពារប្រព័ន្ធគ្រប់គ្រងទិន្នន័យសាលារៀនត្រូវបានកសាងឡើងដោយផ្អែកលើសសរស្តម្ភ ៣ មិនអាចខ្វះបាន ដែលគេហៅថា **CIA Triad**៖



ភាពសម្ងាត់

CONFIDENTIALITY

ធានាថាទិន្នន័យផ្ទាល់ខ្លួន ព័ត៌មានសិស្ស ពិន្ទុ និងលេខសម្ងាត់ អាចមើលឃើញតែបុគ្គលដែលមានសិទ្ធិស្របច្បាប់ប៉ុណ្ណោះ។



ភាពសុចរិត

INTEGRITY

ធានាថាទិន្នន័យពិន្ទុ វិញ្ញាបនបត្រ ត្រាសាលា និងតួនាទី (Role) មិនអាចត្រូវគេលួចកែប្រែ ឬក្លែងបន្លំដោយខុសច្បាប់ឡើយ។



ភាពមានប្រើប្រាស់

AVAILABILITY

ធានាថាប្រព័ន្ធដំណើរការ ២៤/៧ មិនគាំង មិនដាច់ ដោយសារការវាយប្រហារសាកល្បងលេខសម្ងាត់ (Brute-Force) ឬការដាច់សេវា។

២. ហានិភ័យទូទៅនៃការវាយប្រហារលើប្រព័ន្ធគេហទំព័រ

កម្មវិធីគ្រប់គ្រងសាលារៀន ជាផ្នាំងស៊ីបដ៏សំខាន់របស់ Hacker ដោយសារមានទិន្នន័យពិន្ទុ និងអត្តសញ្ញាណមនុស្សរាប់រយនាក់។ ខាងក្រោមជាទម្រង់វាយប្រហារចម្បងៗ និងដំណោះស្រាយក្នុងប្រព័ន្ធយើង៖

ឈ្មោះការវាយប្រហារ	និយមន័យ និងយន្តការ	វិធានការដោះស្រាយក្នុងប្រព័ន្ធយើង
Privilege Escalation (ការដំឡើងសិទ្ធិដោយខុសច្បាប់)	Hacker បន្លំជាគ្រូបង្រៀន រួចព្យាយាមបញ្ជូនសំណើដើម្បីគ្រប់គ្រងទំព័រ Admin ឬកែ Role ខ្លួនឯងជា ADMIN។	ឆែកសិទ្ធិនៅ Server តាម `AuthInterceptor` ជាដាច់ខាត និងគ្មាន API ណាអនុញ្ញាតឱ្យគ្រូកែប្រែ Role ឡើយ។
Brute-Force Attack (ការទាយលេខសម្ងាត់ស្វ័យប្រវត្តិ)	ប្រើប្រាស់កូដ Robot បាញ់សាកល្បងទាយពាក្យសម្ងាត់រាប់ពាន់ដងក្នុងមួយវិនាទី ដើម្បីទម្លាយចូលគណនី Admin។	កំណត់ `LoginRateLimiter` ត្រឹម ៥ ដងខុសជាប់គ្នា នោះ IP នឹងត្រូវចាក់សោបិទ (Lockout) ១០ នាទី។
Cookie Tampering / IDOR (ការកែប្រែ Cookie បន្លំអត្តសញ្ញាណ)	លួចកែតម្លៃ Cookie `REMEMBER_ACCOUNT_ID` ពីលេខ 97 ទៅលេខ 1 (Admin) ដើម្បីបន្លំចូលដោយមិនបាច់ Login។	ចុះហត្ថលេខាឌីជីថលសម្ងាត់តាមក្បួន `HMAC-SHA256` ជាមួយ Secret Key របស់ Server និង Hash របស់ User។
Information Disclosure (ការលេចធ្លាយទិន្នន័យសម្ងាត់)	ស្វែងរកផ្លូវកាត់ដូចជា Debug URLs ឬ Database Web Console ដែលអ្នកអភិវឌ្ឍន៍ភ្លេចបិទ។	លុបចោលទាំងស្រុងនូវ `/debug/accounts` និងបិទ H2 Database Web Console ទាំងស្រុង។
Clickjacking & MIME Sniffing (ការបន្លំចុច និងបន្លំប្រភេទឯកសារ)	បង្កប់គេហទំព័រក្នុង iFrame ដើម្បីបញ្ឆោតឱ្យ Admin ចុចលុបទិន្នន័យ ឬបន្លំឯកសាររូបភាពជាកូដមេរោគ។	បន្ថែម `SecurityHeadersFilter` (X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff)។

៣. ស្ថាបត្យកម្មការពារ ៦ ស្រទាប់នៃប្រព័ន្ធ (The 6-Layer Architecture)

ដើម្បីធានាថាគ្មានចន្លោះប្រហោងណាអាចឱ្យ Hacker ជ្រៀតចូលបាន ប្រព័ន្ធគ្រប់គ្រងថ្នាក់រៀន ២០២៧ ត្រូវបានរចនាឡើងជាមួយ **រចាំង ការពារ ៦ ស្រទាប់រឹងមាំ (Defense in Depth)**៖

ស្រទាប់ទី ១	**HTTP Security Headers & Transport Security** ការពារ Clickjacking, MIME Confusion, និងកំណត់ Secure/HttpOnly Cookies	`SecurityHeadersFilter.ja`
ស្រទាប់ទី ២	**Login Rate Limiter & Brute-Force Lockout** កំណត់ឱ្យទាយលេខសម្ងាត់បានត្រឹម ៥ ដងខុស រួចចាក់សោបិទ ១០ នាទី	`LoginRateLimiter.java`
ស្រទាប់ទី ៣	**Cryptographic HMAC-SHA256 Cookie Signing** ចុះហត្ថលេខាឌីជីថលលើ Cookie ការពារមិនឱ្យកែលេខសម្គាល់ IDOR	`TokenSecurityService.java`
ស្រទាប់ទី ៤	**Zero-Trust Server-Side RBAC (Role-Based Access Control)** ឆែកសិទ្ធិ ADMIN ផ្ទាល់នៅកម្រិត Server មុន Controller ដំណើរការ	`AuthInterceptor.java`
ស្រទាប់ទី ៥	**Attack Surface Hardening & Information Secrecy** លុប Debug URL, បិទ H2 Database Web Console, ញែកដាច់ត្រា និងហត្ថលេខា	`CertificateController.ja`
ស្រទាប់ទី ៦	**Data Isolation per Account & Disaster Recovery** ញែកដាច់ថ្នាក់រៀនតាមគណនីគ្រូ, Database Persistence, យន្តការ Backup SQL	`classroomDB & data_dump`

ស្រទាប់ទី ១៖ HTTP Security Headers & Transport Security

ត្រូវបានគ្រប់គ្រងដោយ `SecurityHeadersFilter.java` ដោយបន្ថែម Headers ការពារលើគ្រប់ HTTP Response៖

```
// ដាក់បញ្ចូល Security Headers ស្តង់ដារពិភពលោក
httpResponse.setHeader("X-Frame-Options", "SAMEORIGIN");        // ការពារ Clickjacking
httpResponse.setHeader("X-Content-Type-Options", "nosniff");    // ការពារ MIME Sniffing
httpResponse.setHeader("X-XSS-Protection", "1; mode=block");    // ការពារ Cross-Site Scripting
httpResponse.setHeader("Referrer-Policy", "strict-origin-when-cross-origin");
```

ស្រទាប់ទី ២៖ ប្រព័ន្ធទប់ស្កាត់ការទាយពាក្យសម្ងាត់ (Login Rate Limiter)

ដំណើរការតាមរយៈ `LoginRateLimiter.java` ដោយរាប់ចំនួនដងនៃការ Login ខុសតាមអាសយដ្ឋាន IP របស់ឧបករណ៍ស្នើសុំ៖

```
public synchronized boolean recordFailureAndCheckLockout(String clientIp) {
    AttemptRecord record = attempts.computeIfAbsent(clientIp, k → new AttemptRecord());
    record.failedAttempts++;
    if (record.failedAttempts ⩾ 5) { // ខុស ៥ ដង
        record.lockoutUntil = System.currentTimeMillis() + (10 * 60 * 1000); // ចាក់សោ ១០ នាទី
        return true; // កំពុងជាប់ Lockout
    }
    return false;
}
```

ស្រទាប់ទី ៣៖ ការពារ Cookie ដោយហត្ថលេខាឌីជីថល (HMAC-SHA256)

ការពារភាពងាយរងគ្រោះ Insecure Direct Object Reference (IDOR) ដោយ `TokenSecurityService.java`៖

```
// ទម្រង់ Cookie ថ្មី៖ ID.AccountSecretHash.HMAC_Signature
// ប្រសិនបើ Hacker កែប្រែ ID នោះ HMAC Signature នឹងលែងត្រូវគ្នា ហើយ Cookie ត្រូវលុបចោលភ្លាម
String expectedSignature = hmacSha256(dataToSign, hmacSecret);
if (!MessageDigest.isEqual(expectedSignature.getBytes(), providedSignature.getBytes())) {
    return Optional.empty(); // បដិសេធភ្លាមៗ!
}
```

ស្រទាប់ទី ៤៖ ការត្រួតពិនិត្យសិទ្ធិតាមម៉ាស៊ីនបម្រើ (Zero-Trust Server-Side RBAC)

គ្រប់ Request ទាំងអស់ចូលទៅកាន់ `/admin/**` ត្រូវបានត្រួតពិនិត្យដោយ `AuthInterceptor.java` ជាមុនសិន។ ទោះបីជា Hacker កែប្រែ JavaScript លើ Browser របស់គាត់ក៏ដោយ ក៏ Server មិនអនុញ្ញាតឡើយ៖

```
// Admin paths require ADMIN role strictly on server side
if (path.startsWith("/admin")) {
    String role = (String) session.getAttribute("ACCOUNT_ROLE");
    if (role == null || !"ADMIN".equals(role)) {
        response.sendRedirect("/login"); // បណ្តេញចេញទៅទំព័រ Login ភ្លាមៗ
        return false;
    }
    return true;
}
```

ស្រទាប់ទី ៥៖ ការកាត់បន្ថយផ្ទៃវាយប្រហារ (Attack Surface Hardening)

- **លុបចោល Endpoint សម្ងាត់៖** បានលុបចោលទាំងស្រុងនូវ `/debug/accounts` ដែលធ្លាប់បង្ហាញ Username និង Password។
- **បិទច្រក H2 Database Web Console៖** ដាក់ `spring.h2.console.enabled=false` និងរារាំងផ្លូវ `/h2-console/**` មិនឱ្យជនខាងក្រៅបើក Database បានឡើយ។
- **ញែកដាច់ហត្ថលេខា និងត្រាសាលា (Signature Isolation)៖** កែប្រែ `CertificateController.java` ឱ្យគ្រូម្នាក់ៗអាចផ្ទុកឡើង និងប្រើប្រាស់បានតែត្រា និងហត្ថលេខារបស់ខ្លួន មិនអាចកែប្រែជាន់លើ Admin ឬគ្រូដទៃឡើយ។

---

៤. វិភាគករណីសិក្សាជាក់ស្តែង (Practical Attack Scenarios & Defenses)

🚨 សេណារីយ៉ូទី ១៖ Hacker លួចបានលេខសម្ងាត់គ្រូ រួចព្យាយាមចូលទំព័រគ្រប់គ្រង /admin/accounts

Hacker ប្រើប្រាស់គណនីគ្រូ Login បានសម្រេច រួចវាយបញ្ចូល URL ដោយផ្ទាល់ `https://class.mitpukae.com/admin/accounts` ឬប្រើ Postman បាញ់ POST ទៅ `/admin/accounts/update` ដើម្បីប្តូរលេខសម្ងាត់ Admin។

🛡️ ការឆ្លើយតបទប់ស្កាត់របស់ប្រព័ន្ធ៖ `AuthInterceptor` **ឆែកឃើញ Session មាន** `ACCOUNT_ROLE = "TEACHER"` **។ លក្ខខណ្ឌ** `!"ADMIN".equals(role)` **ត្រូវជាពិត Server កាត់ផ្តាច់ដំណើរការភ្លាមៗ បញ្ជូន HTTP 302 Redirect ទៅកាន់** `/login` **ដោយមិនអនុញ្ញាតឱ្យកូដ Admin ដំណើរការសូម្បីតែមួយបន្ទាត់!**

🚨 សេណារីយ៉ូទី ២៖ Hacker ប្រើប្រាស់ Script បាញ់ទាយពាក្យសម្ងាត់ Admin (Dictionary Brute-Force)

Hacker បង្កើត Python Script បាញ់ Username `admin` ជាមួយពាក្យសម្ងាត់រាប់ពាន់ពាក្យតាមរចនានុក្រម (password123, 123456, admin2027...)។

🛡️ ការឆ្លើយតបទប់ស្កាត់របស់ប្រព័ន្ធ៖ នៅពេល Login ខុសដល់លើកទី ៥ `LoginRateLimiter` **ចាប់ផ្តើមចាក់សោ IP នោះភ្លាម។ រាល់ Request លើកទី ៦, ៧, ៨... ត្រូវ Server ច្រានចោលត្រឹម 0.001 វិនាទី ដោយឆ្លើយតបថា** ***«ការចូលត្រូវបានចាក់សោបណ្តោះអាសន្ន ១០ នាទី!»*** **ការវាយប្រហារត្រូវបរាជ័យទាំងស្រុង។**

🚨 **សេណារីយ៉ូទី ៣៖ Hacker ប្រើ Developer Tools កែ Cookie REMEMBER_ACCOUNT_ID ទៅលេខ 1 (Admin)**

Hacker ដឹងថា Admin មាន ID = 1 ដូច្នេះគាត់ចូល Browser Developer Tools រួចកែតម្លៃ Cookie ផ្ទាល់ខ្លួនពី ID គ្រូ ទៅលេខ 1 សង្ឃឹមថា Refresh មកក្លាយជា Admin។

🛡️ **ការឆ្លើយតបទប់ស្កាត់របស់ប្រព័ន្ធ៖** `TokenSecurityService` **ពិនិត្យឃើញថា តម្លៃ Token គ្មានហត្ថលេខាឌីជីថលសម្ងាត់ត្រឹមត្រូវ (Invalid HMAC Signature)។ ប្រព័ន្ធមិនត្រឹមតែបដិសេធការ Login នោះទេ ប៉ុន្តែថែមទាំងចេញបញ្ជា** `Set-Cookie: maxAge=0` **ដើម្បីលុប Cookie ក្លែងបន្លំនោះចោលពី Browser ទៀតផង!**

៥. បញ្ជីត្រួតពិនិត្យសម្រាប់អ្នកគ្រប់គ្រង (Admin Security Checklist)

ដើម្បីធានាថាកម្រិតសុវត្ថិភាពស្ថិតនៅចំណុចខ្ពស់បំផុត ១00% អ្នកគ្រប់គ្រងសាលា (Administrator) ត្រូវអនុវត្តជាប្រចាំនូវវិធានការខាងក្រោម៖

- ☑ **ផ្លាស់ប្តូរពាក្យសម្ងាត់ដើម (Default Password) ជាបន្ទាន់៖**
  ហាមប្រើ `admin / admin123` ដាច់ខាត! ត្រូវចូលទៅកាន់ `/admin/accounts` កែប្រែ Username និង Password របស់ Admin ឱ្យមានប្រវែងយ៉ាងតិច ១២ ខ្ទង់ រួមបញ្ចូលអក្សរធំ អក្សរតូច លេខ និងសញ្ញាពិសេស (ឧ. `Admin@Nubb2027#Secure!`)។

- ☑ **បិទដំណើរការគណនីគ្រូដែលឈប់បង្រៀន (Disable Inactive Teachers)៖**
  ប្រសិនបើមានលោកគ្រូ-អ្នកគ្រូផ្លាស់ប្តូរទៅសាលាផ្សេង ឬឈប់បង្រៀន Admin គ្រាន់តែចុចបិទដំណើរការ (Disable) ក្នុងបញ្ជីគណនី នោះគណនីនោះនឹងត្រូវកាត់ផ្តាច់ Session ភ្លាមៗ។

- ☑ **ទាញយកទិន្នន័យបម្រុងទុក (Export Database Backups) ជារៀងរាល់ខែ៖**
  ទាញយកឯកសារ SQL Dump រក្សាទុកក្នុង External Hard Drive ឬ Google Drive ផ្ទាល់ខ្លួន ដើម្បីការពារករណីឧបទ្ទវហេតុបាត់បង់ទិន្នន័យដោយចាហេតុ។

- ☑ **បណ្តុះបណ្តាលលោកគ្រូ-អ្នកគ្រូអំពីការរក្សាការសម្ងាត់៖**
  ណែនាំមិនឱ្យចែករំលែកគណនី និងលេខសម្ងាត់ទៅឱ្យសិស្ស ឬអ្នកដទៃ និងត្រូវ Logout ចេញជានិច្ចនៅពេលប្រើប្រាស់លើកុំព្យូទ័រសាធារណៈ។

> ⚠️ **ចំណាំសំខាន់បំផុត៖**
> ប្រព័ន្ធបច្ចេកវិទ្យាអាចការពារបាន ៩៩% តែ ១% ទៀតគឺស្ថិតលើ
> **«កត្តាមនុស្ស (Human Factor)»**
> ។ ការរក្សាការសម្ងាត់នៃពាក្យសម្ងាត់គឺជាខែលការពារដ៏រឹងមាំបំផុត!

---

៦. វចនានុក្រមបច្ចេកទេសសុវត្ថិភាព (Security Glossary)

ពាក្យបច្ចេកទេស (English)	ពាក្យខ្មែរ	ការពន្យល់សង្ខេប
`Authentication (AuthN)`	ការផ្ទៀងផ្ទាត់អត្តសញ្ញាណ	ការបញ្ជាក់ថា "តើអ្នកជានរណា?" តាមរយៈ Username និង Password។
`Authorization (AuthZ)`	ការអនុញ្ញាតសិទ្ធិ	ការបញ្ជាក់ថា "តើអ្នកមានសិទ្ធិធ្វើអ្វីខ្លះ?" ដូចជា ADMIN ឬ TEACHER។
`Brute-Force Attack`	ការវាយប្រហារសាកទាយលេខសម្ងាត់	ការប្រើប្រាស់កុំព្យូទ័រទាយពាក្យសម្ងាត់ម្តងមួយៗរហូតដល់ត្រូវ។
`Rate Limiting`	ការកម្រិតចំនួនដងនៃការស្នើសុំ	ការកំណត់ឱ្យ User ឬ Bot អាច Login បានត្រឹមចំនួនដងកំណត់មួយក្នុងមួយឯកតាពេល។
`HMAC-SHA256`	ក្បួនគណនាហត្ថលេខាឌីជីថលសម្ងាត់	ក្បួនគណិតវិទ្យាសម្ងាត់ ដើម្បីធានាថាទិន្នន័យ Cookie មិនត្រូវបានគេលួចកែប្រែ។
`IDOR`	ការយោងវត្ថុដោយផ្ទាល់គ្មានសុវត្ថិភាព	ភាពងាយរងគ្រោះដែល Hacker ប្តូរលេខសម្គាល់ ID ដើម្បីលួចទិន្នន័យអ្នកដទៃ។
`RBAC`	ការគ្រប់គ្រងសិទ្ធិតាមតួនាទី	Role-Based Access Control (ការកំណត់សិទ្ធិដាច់ដោយឡែករវាងគ្រូ និង Admin)។
`Zero Trust`	គោលការណ៍ "មិនទុកចិត្តអ្វីទាំងអស់"	យុទ្ធសាស្ត្រសុវត្ថិភាពដែលតម្រូវឱ្យ Server ត្រួតពិនិត្យសិទ្ធិគ្រប់សំណើទាំងអស់។